

数据安全与个人信息保护规范

技术规范文件

保险公司 技术开发部
内部文档 · 仅供授权人员查阅

目录

- 1. 概述
- 2. 个人信息分类
 - 2.1 保险行业个人信息分级
 - 2.2 个人信息处理原则
- 3. 技术保护措施
 - 3.1 数据加密
 - 3.2 数据脱敏
 - 3.3 访问控制
- 4. 个人信息保护影响评估(PIA)
- 5. 数据生命周期管理
- 6. 用户权利响应

数据安全与个人信息保护规范

1. 概述

本文档定义保险技术平台在数据安全和个人信息保护方面的技术规范，落实《个人信息保护法》(PIPL)、《数据安全法》及金融行业监管要求。适用于所有涉及个人数据处理的应用系统开发和运维。

2. 个人信息分类

2.1 保险行业个人信息分级

级别	定义	数据示例	保护要求
L4 极度敏感	泄露可能导致严重人身/财产损失	银行卡号+密码、生物信息(指纹/人脸)	加密存储+传输，访问需审批+高安全审计
L3 高度敏感	泄露可能导致重大风险	身份证号、手机号、家庭住址、健康信息	加密存储，最小授权，脱敏显示
L2 一般敏感	泄露可能导致一般风险	姓名、性别、电子邮箱、保单信息	内部隔离，按需授权
L1 非敏感	泄露风险较低	脱敏数据、统计数据	基本访问控制

2.2 个人信息处理原则

- 合法正当必要: 仅收集业务所必需的信息
- 告知同意: 收集前告知目的、方式、范围，取得明确同意
- 目的限制: 不超出收集时告知的目的使用
- 数据最小化: 仅保留业务所需的最少数据
- 准确性: 提供渠道供客户更正个人信息
- 存储限制: 超出保留期限的及时删除或匿名化

3. 技术保护措施

3.1 数据加密

场景	加密方案	算法
数据传输	全站 HTTPS TLS 1.3	TLS 1.3
数据库存储	透明数据加密(TDE)	AES-256
字段级加密	应用层加密	AES-256-GCM
备份数据	存储加密	AES-256
密钥管理	集中密钥管理系统	定期轮转(90天)

3.2 数据脱敏

数据类型	脱敏方式	示例	脱敏后
姓名	保留姓氏，名用*代替	张三丰	张**
手机号	中间4位掩码	13812345678	138****5678

数据类型	脱敏方式	示例	脱敏后
身份证号	保留前6后4	110101199001011234	110101****1234
银行卡号	保留前4后4	6222021234567890	6222****7890
地址	保留到市级	北京市海淀区...	北京市**
邮箱	@前保留首 字符+***	zhangsan@mail.com	z***@mail.com

脱敏规则统一配置在数据安全平台，各系统调用脱敏SDK，不得自行实现。

3.3 访问控制

控制点	要求
用户认证	SSO + MFA(管理后台强制)
数据访问	RBAC/ABAC 细粒度权限模型
数据库访问	白名单 IP + 代理访问，禁止直连
批量导出	必须审批，导出文件加密
接口鉴权	JWT + Scope，敏感接口额外验签
日志审计	所有数据访问操作留存

4. 个人信息保护影响评估(PIA)

下列情形需启动 PIA：

1. 处理敏感个人信息
2. 自动化决策（如智能核保、智能理赔）
3. 委托处理个人信息（如第三方定损平台）
4. 向境外提供个人信息
5. 处理大量个人信息(>100万条)

PIA 流程：

□□□□ → □□□□ → □□□□ → □□□□ → □□□□ → □□□□

5. 数据生命周期管理

阶段	管理要求	技术实现
采集	最小化、告知同意	表单设计审核、埋点审批
存储	分级加密	加密SDK、KMS集成
使用	脱敏、授权	脱敏中间件、权限平台
传输	加密通道	TLS、国密SM2/SM4
共享	合同约定+审计	数据共享平台，接口日志
销毁	安全删除	物理销毁/覆写/标记删除
备份	加密	备份加密存储

6. 用户权利响应

权利	技术实现	SLA
知情权	隐私政策页面、数据地图	-

权利	技术实现	SLA
同意撤回	提供撤回机制，撤回后停止处理	T+0
查阅权	客户中心API查询个人信息	T+0
更正权	个人资料修改入口	T+0
删除权	销户/删除工单流程	T+15
可携带权	结构化数据导出	T+7